

Change record — P4 Endpoint Hardening and Windows 11 Readiness

Change record written to the standard Halden uses for every change (feeds the change log and the P10 governance dashboard). In a small company the same person often proposes and approves; that separation is documented honestly rather than pretended.

Field	Value
Change ID	CHG-2026-004
Title	P4 — Endpoint hardening baseline and Windows 11 readiness: Microsoft baseline via GPO, Defender ASR (audit then block), BitLocker with AD escrow, local admin removal, automated compliance report
Raised by	IT (Muhammad Ibrahim Akmal)
Approved by	Managing Director (<i>business owner of the fictional Halden; see the note on the lab</i>)
Date raised	2026-10-02
Planned implementation	2026-10-02 onwards, phase by phase (Phase 0 → Phase 7)
Category / risk	Endpoint security — Medium risk (user-facing controls; a poorly handled ASR block or BitLocker rollout stops people working)
Affected services	User logons, application launching from email attachments, software installation, device boot (BitLocker), remote management (RDP/WinRM)
Affected systems	DC01 (GPO), DC02 (escrow readers), WS01 (policy/compliance client), WS02 (Tier 0 PAW), one Windows 10 VM (upgrade test)
Depends on	P1 (GPO structure and the <code>WKS - Security Baseline - v1</code> placeholder), P3 (Windows LAPS and privileged-access tiering)
Excluded from this change	Update rings and patch programme (P5), VLAN-level firewall enforcement (P6), SIEM ingestion of the Defender and PowerShell events (P7), server hardening

1. Description of the change

Apply one measured endpoint standard to Halden's Windows clients:

- the **Microsoft Security Baseline** imported into new GPOs with a separate overrides GPO for documented deviations, rolled out to a pilot OU before the fleet;
- Defender Antivirus** hardened (cloud protection, PUA protection, network protection, Controlled Folder Access) with **16 Attack Surface Reduction rules** first in audit and then in block, after a minimum seven-day review and with only documented exceptions;
- BitLocker** XTS-AES 256 with TPM-only startup and recovery keys ****escrowed to Active Directory before any volume is encrypted****, with a tested recovery procedure and a helpdesk runbook;

- **removal of standing local administrator rights** (local Administrators = the LAPS-managed account

and the IT admin group only), with a published software-request process;

- firewall, Credential Guard, LSA protection and PowerShell logging applied consistently;
- an **automated daily compliance report** across nine named controls, producing an HTML report and a

CSV for management reporting;

- a **Windows 11 readiness assessment** with some counts derived from a clearly labelled **synthetic** fleet, and a costed three-option recommendation for management.

All of it is created by idempotent, logged, lab-guarded scripts kept in the repository, alongside a design document, an as-built document, five runbooks and the business artefacts.

2. Reason for the change

Devices were configured individually, staff hold local administrator rights, BitLocker is off, Defender runs on defaults, and around 30% of devices run Windows 10 — unsupported since 14 October 2025. The business therefore cannot answer three basic questions: is a stolen laptop a data breach; is ransomware behaviour actually blocked; and what will it cost to move off Windows 10. The change answers all three with a standard, a measurement and a costed plan, and it produces the daily evidence that keeps the answer true over time.

3. Impact and risk

Area	Impact	Mitigation
Users — software installation	Staff can no longer install software themselves	The request process is published before the change; manager approval plus packaging covers most requests; time-limited elevation covers genuine one-offs; the Service Desk can act first and complete the paperwork afterwards
Users — email attachments and macros	Executable content and macro-spawned processes are blocked	ASR starts in audit mode for at least seven days, with a deliberate test trigger; business macros are handled by exception rather than by switching the rule off
Users — device boot	A BitLocker recovery screen can appear after a firmware change	Helpdesk runbook with identity verification; the pilot tests the recovery path; the recovery key is escrowed before encryption starts
Data	A wrong exclusion would weaken protection; a lost key would mean data loss	Exclusions need a register row with an owner and an expiry; escrow is proven from a DC before encryption; keys are never committed or shared
Operations	A broad GPO change could affect every client at once	Pilot OU first for three days, then rings; Policy Analyzer comparison before rollout; every phase snapshotted
Support	More calls in the first days (missing software, a blocked file)	User comms issued with the change; the "my device is blocked" runbook is written for users, not for IT

4. Implementation plan (phases)

Phase	Work	Window	Verification
0	Design document; capture the "before" endpoint state	2026-10-02	Baseline CSV and HardeningKitty before-score produced
1	Microsoft baseline imported, overrides GPO, Policy Analyzer comparison, pilot ring	Out of hours	gpresult on the pilot; conflict list documented; compliance report runs
2	Defender hardened; 16 ASR rules in audit for 7 days; deliberate test trigger; then block	Days 2-9	Events 1122 reviewed, 1121 after the block, ASR state CSV
3	BitLocker XTS-AES 256 with AD escrow, then a forced-recovery test	Out of hours	Escrow object exists; recovery test succeeds; time recorded
4	Local admin removal; firewall; Credential Guard; LSA protection; PowerShell logging	Out of hours	Local Administrators before/after CSV; VBS status from msinfo32 ; LAPS status CSV
5	Daily compliance report deployed and scheduled	Working hours	endpoint-compliance-<date>.html with an overall percentage
6	Windows 11 readiness assessment; Win10 → 11 upgrade runbook walked through	Working hours	Readiness summary (synthetic fleet, labelled); upgrade runbook completed on a test device
7	README, showcase page, business artefacts, evidence sanitized	Working hours	Definition of Done (AGENTS.md 4.7)

5. Test plan (acceptance)

1. Baseline compliance (CIS/Microsoft score) measured before and after; the "after" figure is at least 90% on the Windows 11 clients.

1. The 16 ASR rules are audited for at least seven days, produce event 1122 during the audit, and produce event 1121 after being switched to block. A deliberate test trigger (an EICAR test file or a Microsoft ASR test document) is stopped.

1. BitLocker protection is on and 100% complete on every in-scope client, and each recovery key is present in Active Directory.

1. A forced-recovery test succeeds: the key is retrieved by a helpdesk user following the identity verification runbook, and the device boots.

1. The local Administrators group contains only the approved members on every in-scope client.
2. The compliance report runs daily and produces both files; the overall percentage is reproducible from the CSV.

1. Adding a standard user to the local Administrators group makes the compliance report fail control C6, and removing them makes it pass.

1. The readiness script classifies both lab clients and the synthetic fleet without error, and the synthetic counts match the generator's summary file exactly.

6. Backout plan

Each phase is snapshotted before it runs (`snap-p4-ph<N>-before`). Backout per control:

Change	Backout
Baseline or overrides GPO	Unlink the GPO (<code>Remove-GPLink</code>) and run <code>gpupdate /force</code> ; delete the GPO only if it should not exist
ASR rules	<code>03-Set-AsrBlock.ps1 -RevertToAudit</code> (single rule or the whole set); the pilot is snapshotted before blocking
BitLocker	<code>Disable-BitLocker -MountPoint C:</code> while the key is still escrowed. Never delete the escrow record — a device that can still boot with no key anywhere is worse than an unencrypted one
Local admin removal	Re-add the affected membership; the before-state CSV is the reference
Firewall / Credential Guard / logging	Revert the specific registry value or unlink the hardening GPO; Credential Guard and LSA protection need a reboot
Compliance report	It measures only; unregistering the scheduled task stops the reports and changes nothing else

Full backout of the whole change is a revert of the phase snapshots plus re-running the previous phase's scripts, which are idempotent.

7. Post-implementation review

To be completed when the last phase is verified: actual completion date, acceptance test results, anything that went wrong, whether any phase overran, and the resulting numbers. Results are recorded in `projects/p04-endpoint-hardening/README.md` with a source file for every number. The synthetic-fleet counts in the readiness report are reconciled against the generator's summary file at that point.

Lab note: this is a home-lab change record for a fictional company (Halden Distribution Ltd.). The technical content, scripts and test plan are real; the business approval line represents the lab owner's decision, not a real customer sign-off. No result is recorded above as achieved — every verification column describes what will be checked, and the results table stays empty until the lab has actually run.